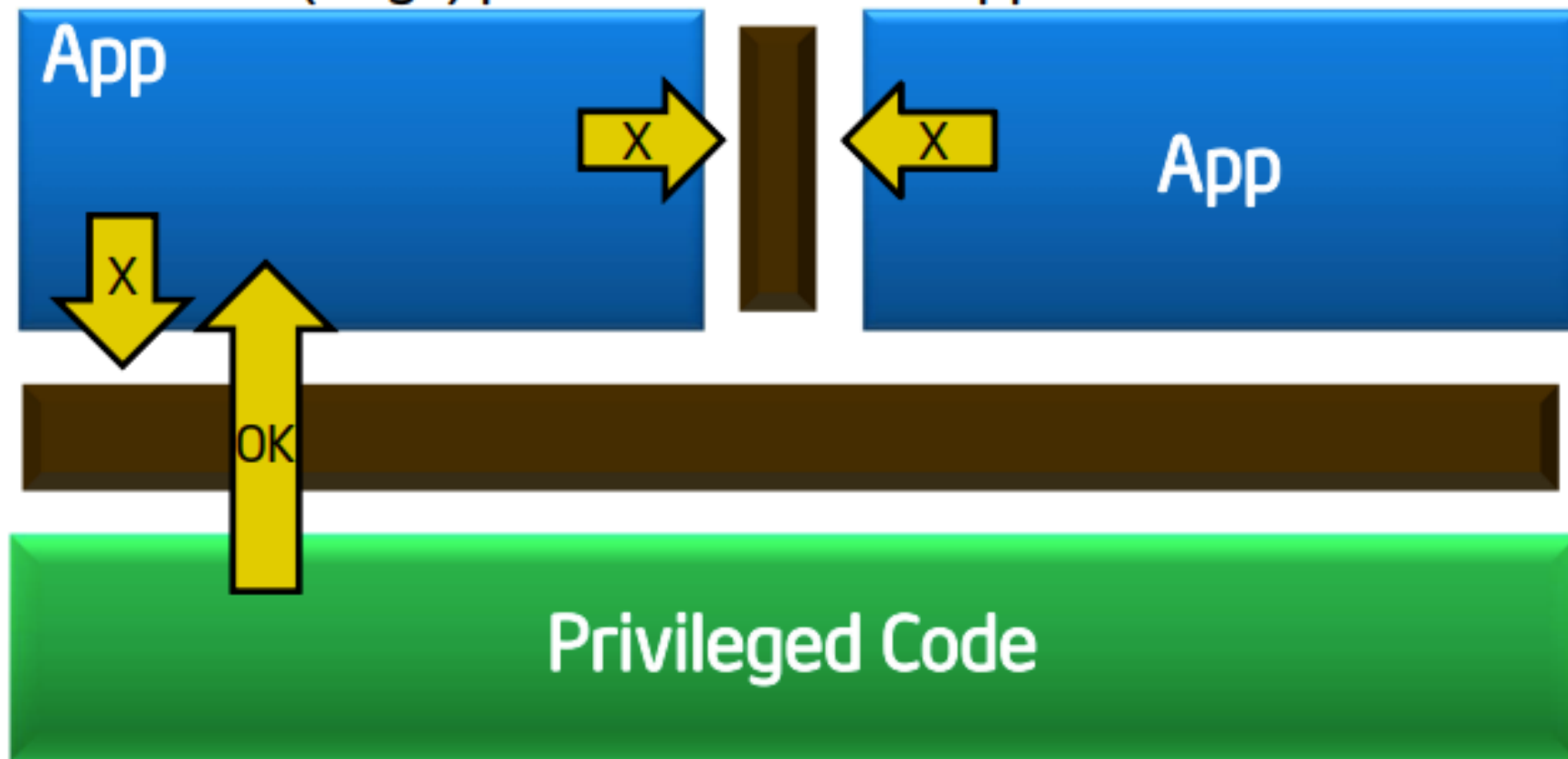




CS773-2025-Spring: Computer Architecture for Performance and Security

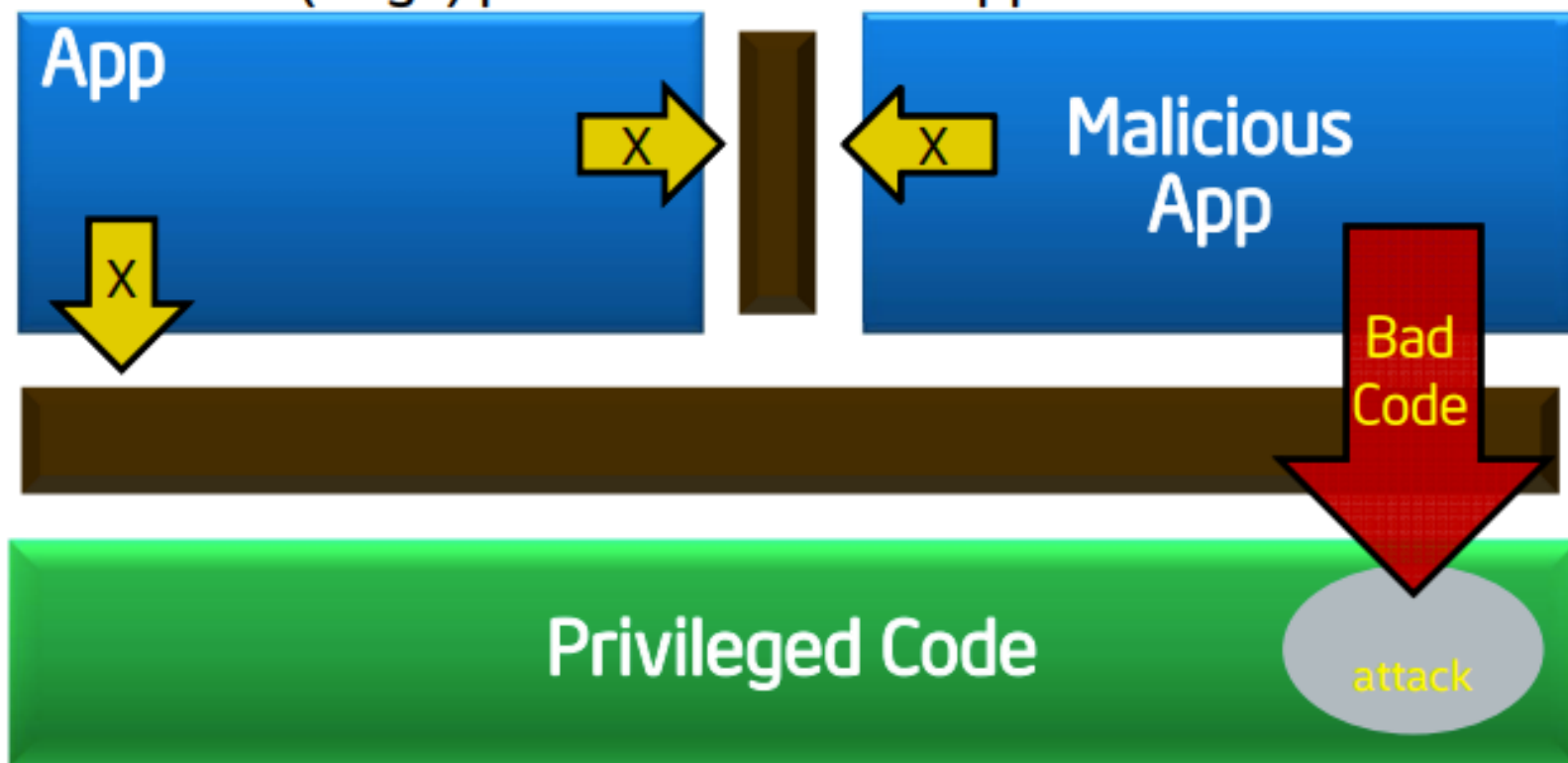
Lecture 17: TEE, Fuzzing, and What Else

Protected Mode (rings) protects OS from apps ...



... and apps from each other ...

Protected Mode (rings) protects OS from apps ...

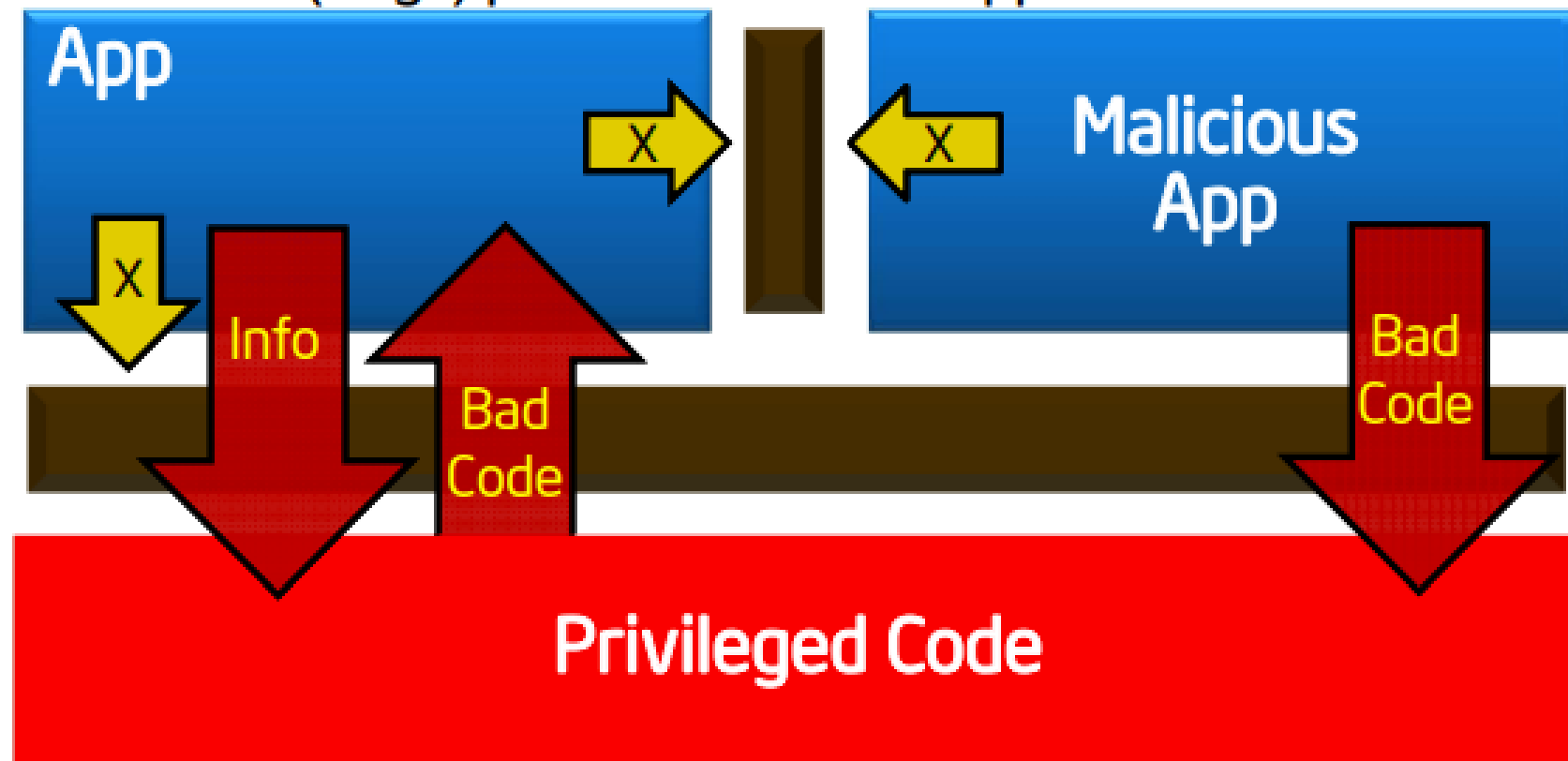


... and apps from each other ...

... UNTIL a malicious app exploits a flaw to gain full privileges and then tampers with the OS or other apps

Apps not protected from privileged code attacks

Protected Mode (rings) protects OS from apps ...



... and apps from each other ...

... UNTIL a malicious app exploits a flaw to gain full privileges and then tampers with the OS or other apps

Apps not protected from privileged code attacks

Home › cyber security › Seven-Year-Old Linux Kernel Bug Opens Door to Remote Code Execution

Seven-Year-Old Linux Kernel Bug Opens Door to Remote Code Execution

Cyber Security

Cyber Security News

Linux

Vulnerability

PUBLISHED ON **FEBRUARY 10, 2025**

BY **AMAN MISHRA**



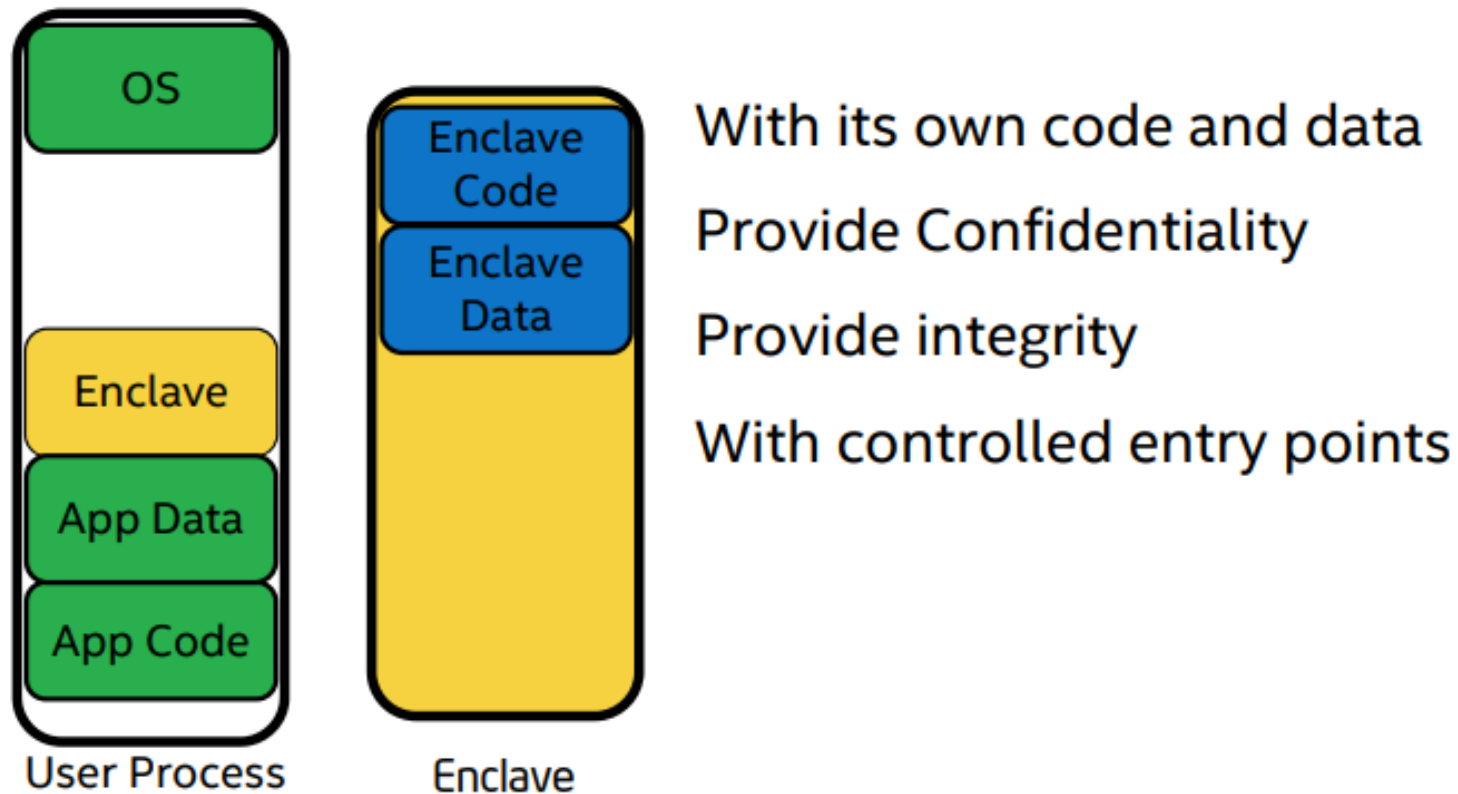
40M lines of code, 8.5 changes per hour 😊

OS is not trusted

- World of malwares and buggy code
- CPU is trusted 😊
- Memory is not 😊 😊
- Need a boss beyond OS

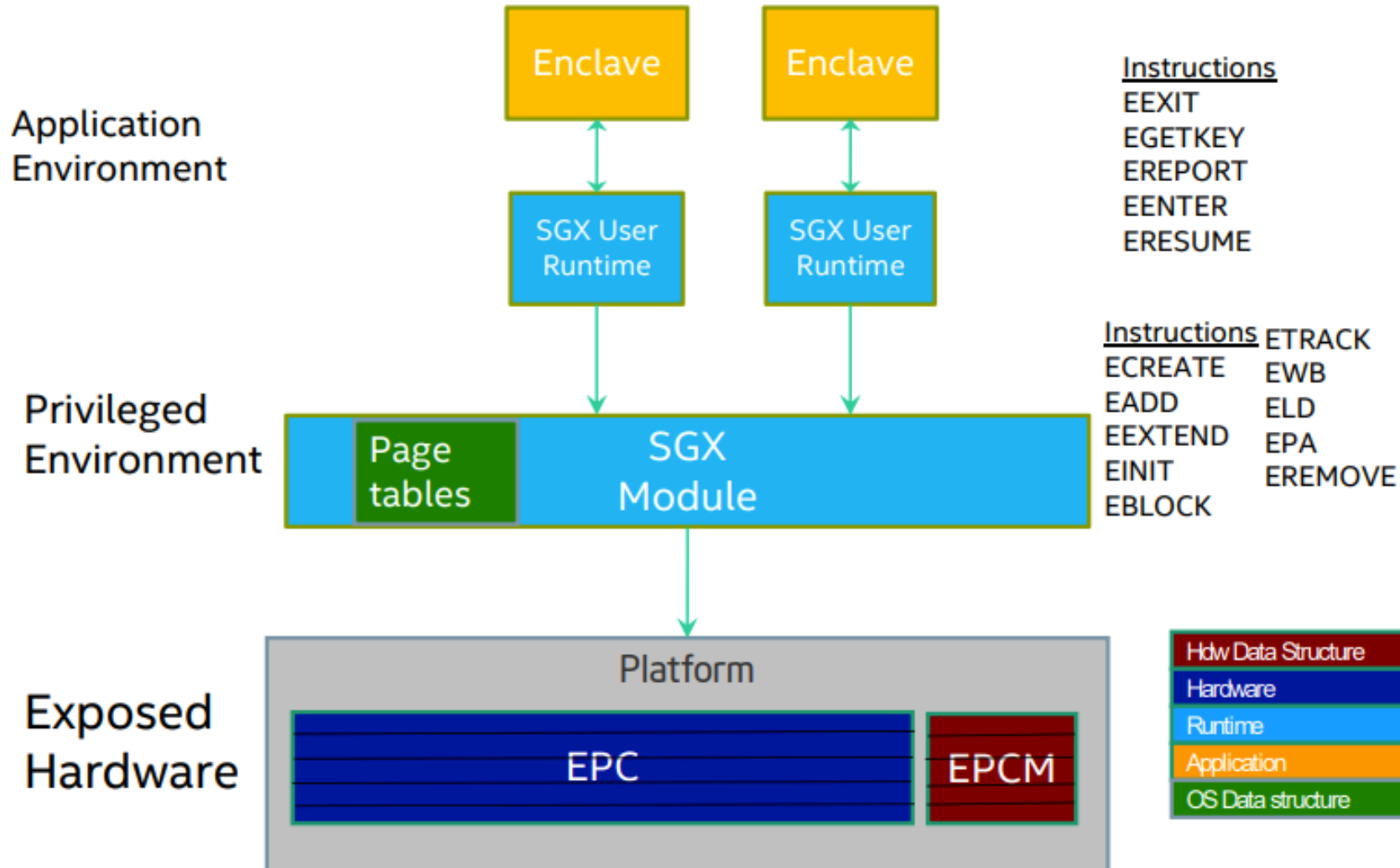
Intel SGX: Software Guarded Extensions

Trusted execution environment embedded in a process

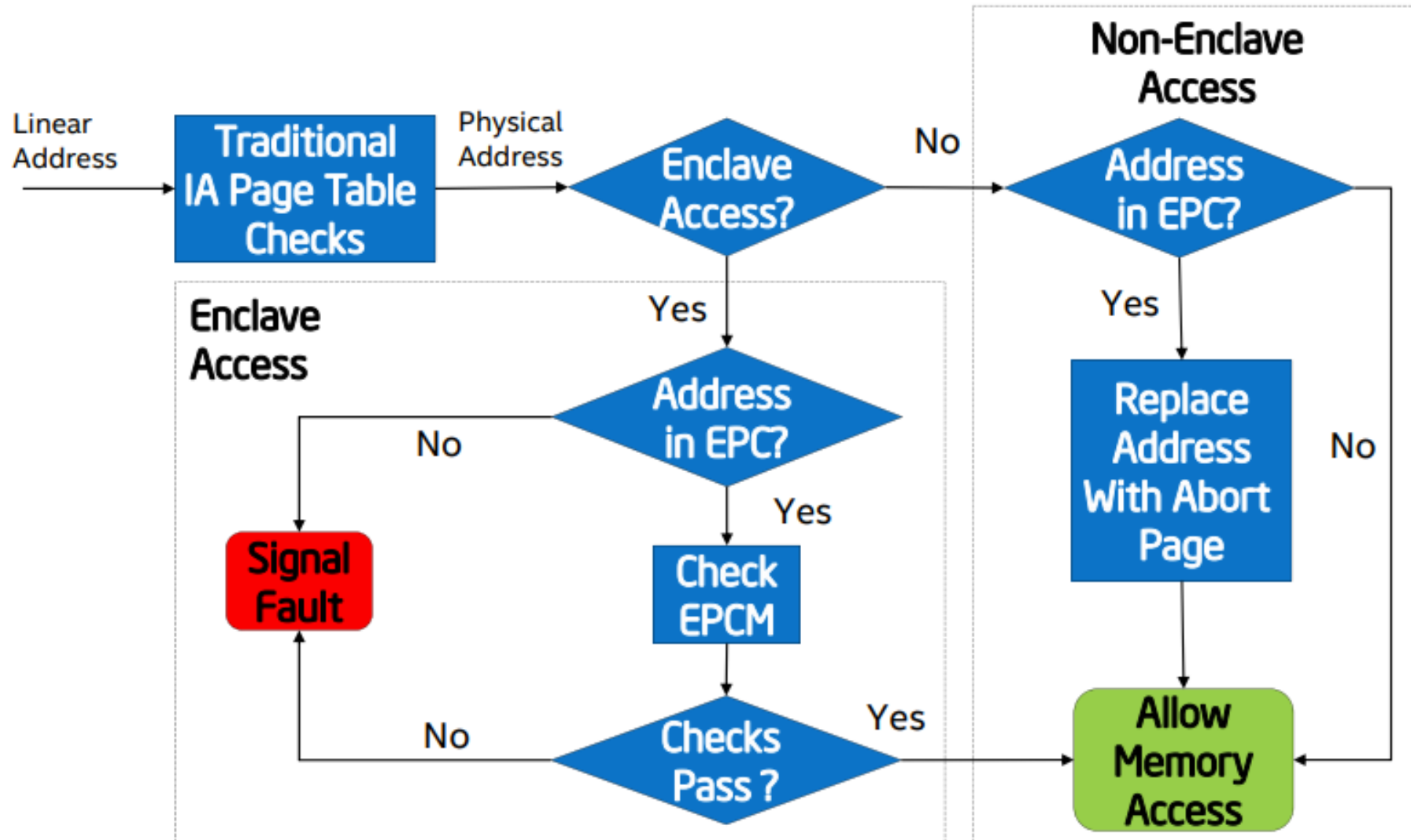


Actually, it does not provide full confidentiality 😊

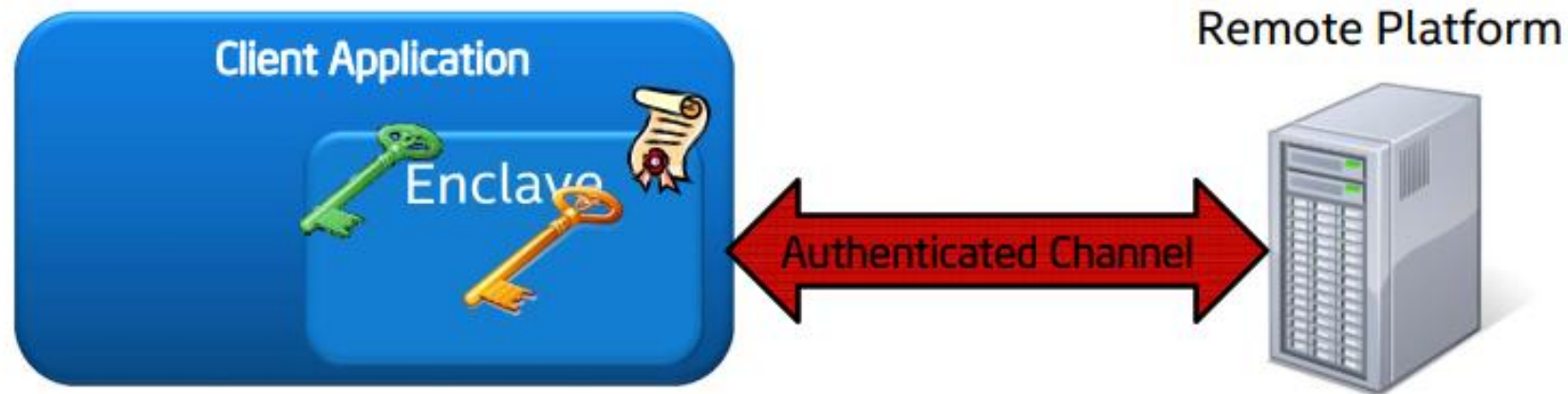
SGX High-level HW/SW Picture



SGX Access Control



Critical Feature: Attestation and Sealing



1. Enclave built & measured
2. Enclave requests REPORT (HW-signed blob that includes enclave identity information)
3. REPORT sent to server & verified
4. Application Key sent to enclave, first secret provisioned
5. Enclave-platform-specific Sealing Key generated (EGETKEY)
6. Application Key encrypted via Sealing Key & stored for later (offline) use

To prove its identity and build trust with an external service. The attestation process uses a series of measurements ...

Attestation

SGX provides LOCAL and REMOTE attestation capabilities

Local attestation allows one enclave to attest its TCB to another enclave on the same platform

Remote attestation allows which one enclave to attest its TCB to another entity outside of the platform

Why?

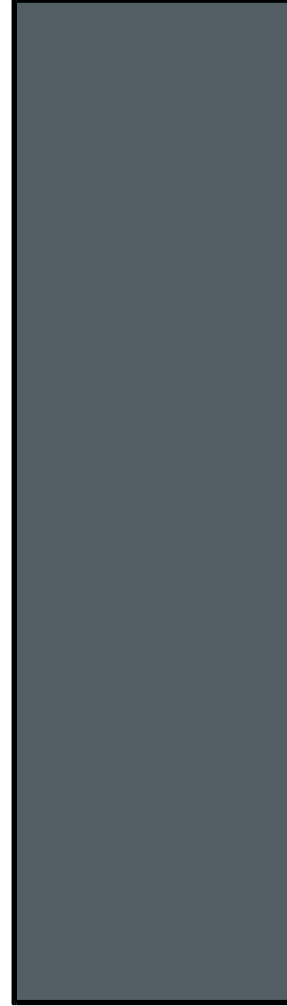
- What if one enclave wants to talk to another enclave
- They need to prove to each other that they are authentic
- Ok. How?
- **Root Provisioning Key (RPK)**: root keys that are fused to SGX CPU at production.
- Intel is also responsible for maintaining a database of all keys ever produced by the HSM.

Life Cycle of An Enclave

Build

1/15

Physical Address Space



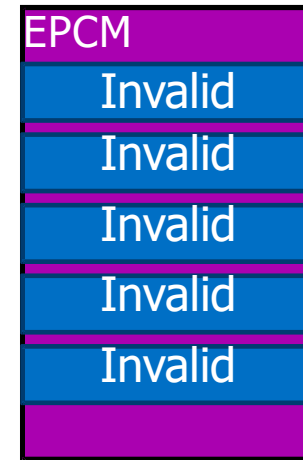
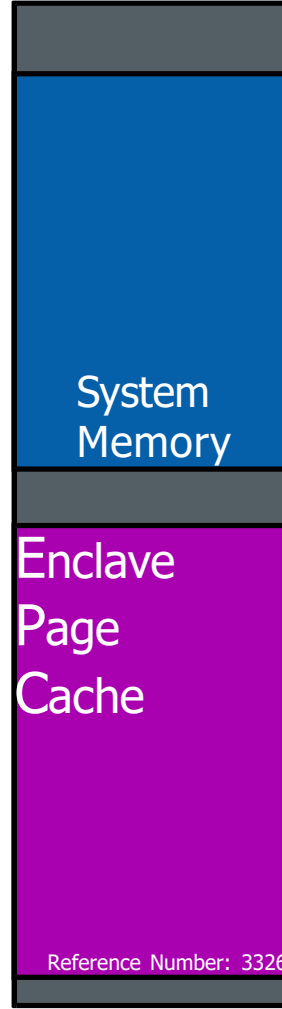
Life Cycle of An Enclave

Build

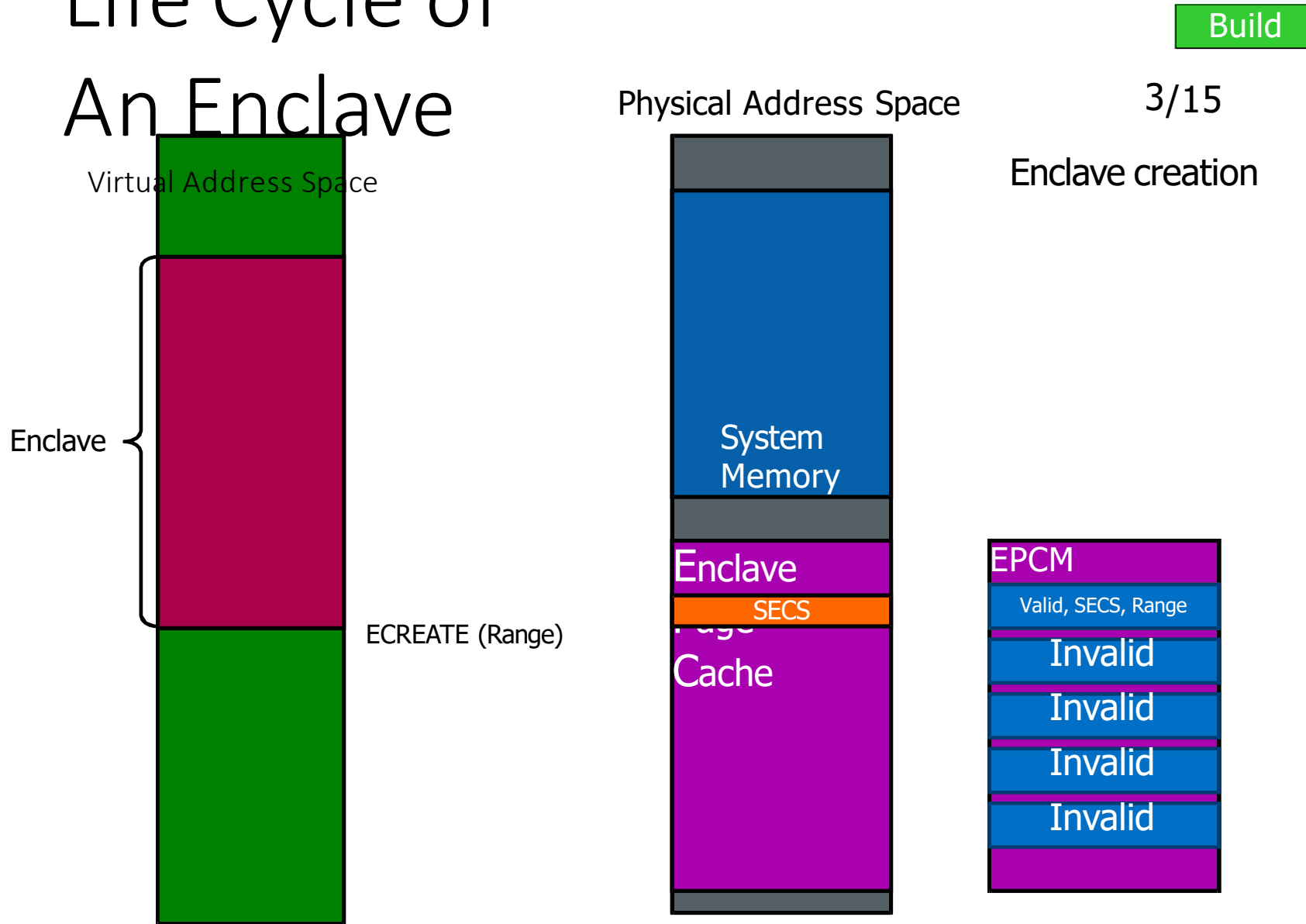
2/15

Physical Address Space

BIOS setup

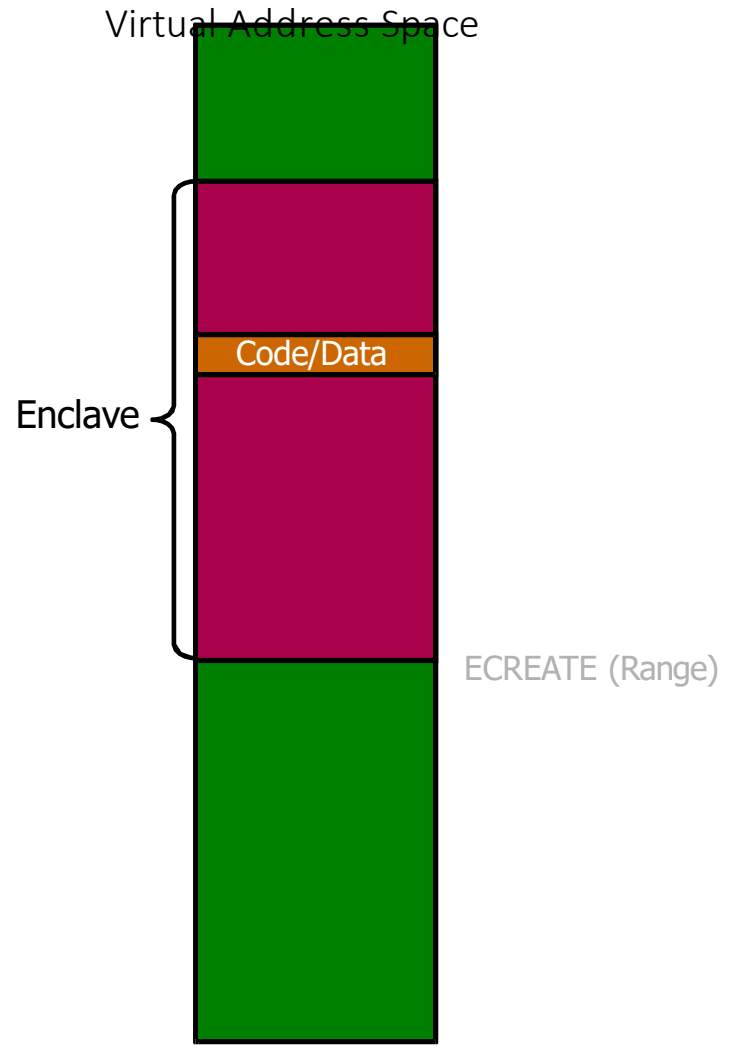


Life Cycle of An Enclave

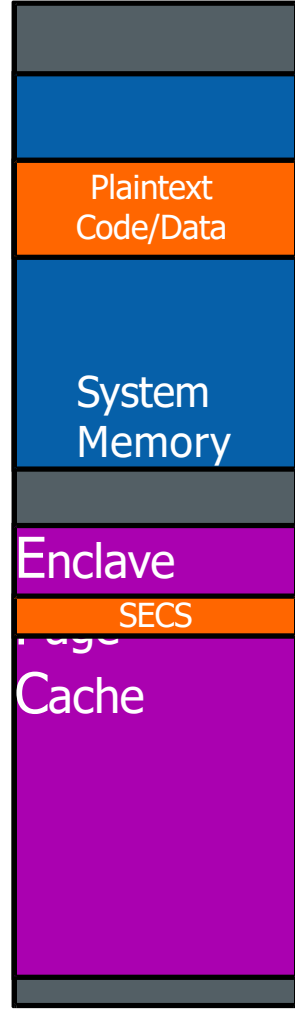


SECS is SGX enclave control structure, contains metadata about an enclave

Life Cycle of An Enclave



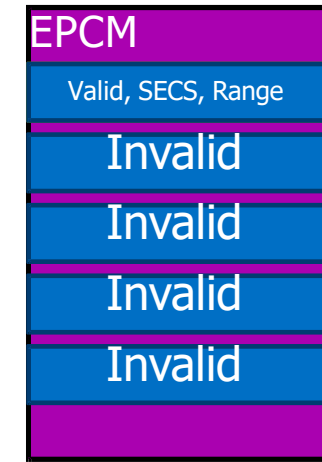
Physical Address Space



Build

4/15

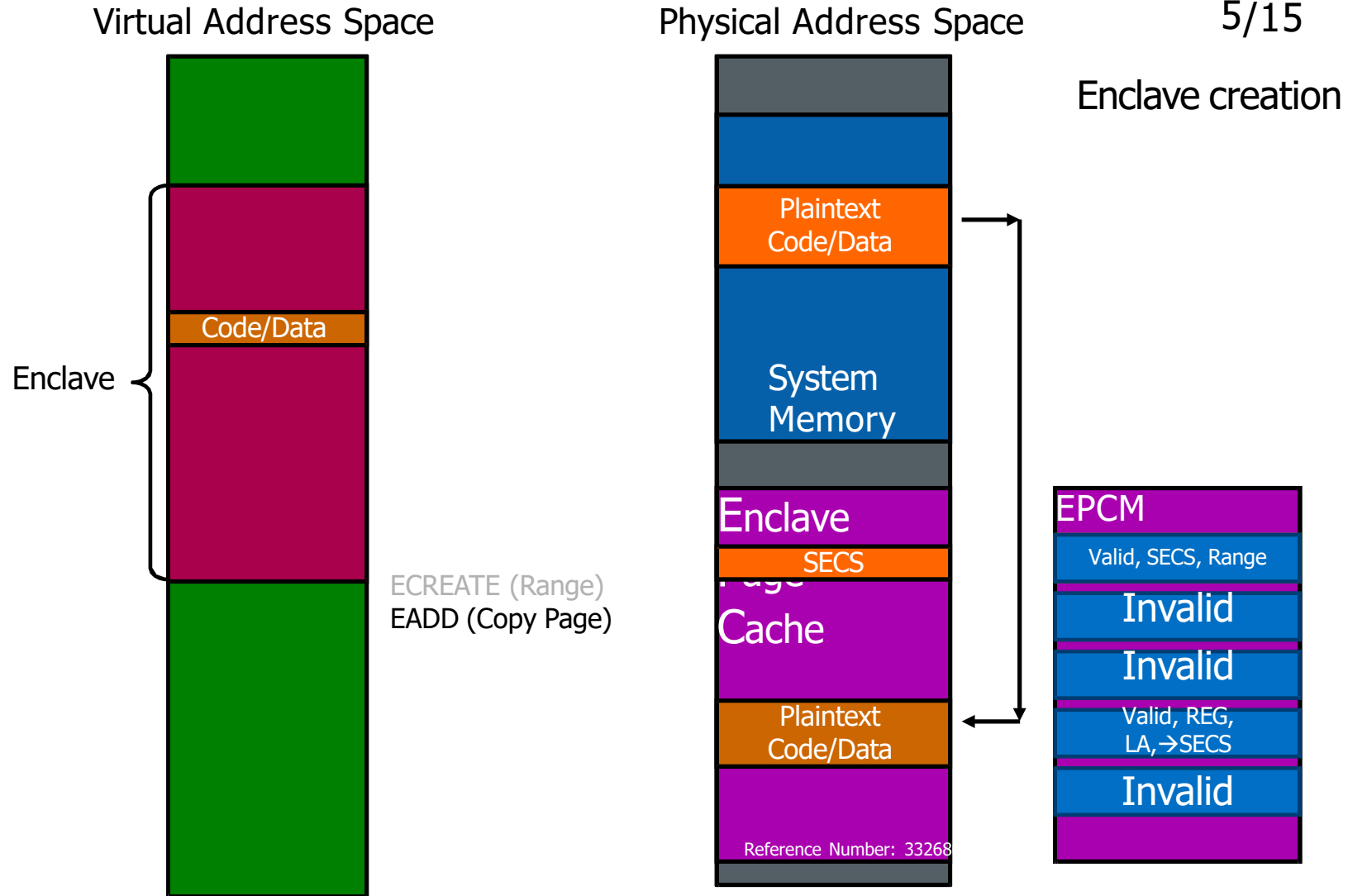
Enclave creation



Life Cycle of An Enclave

Build

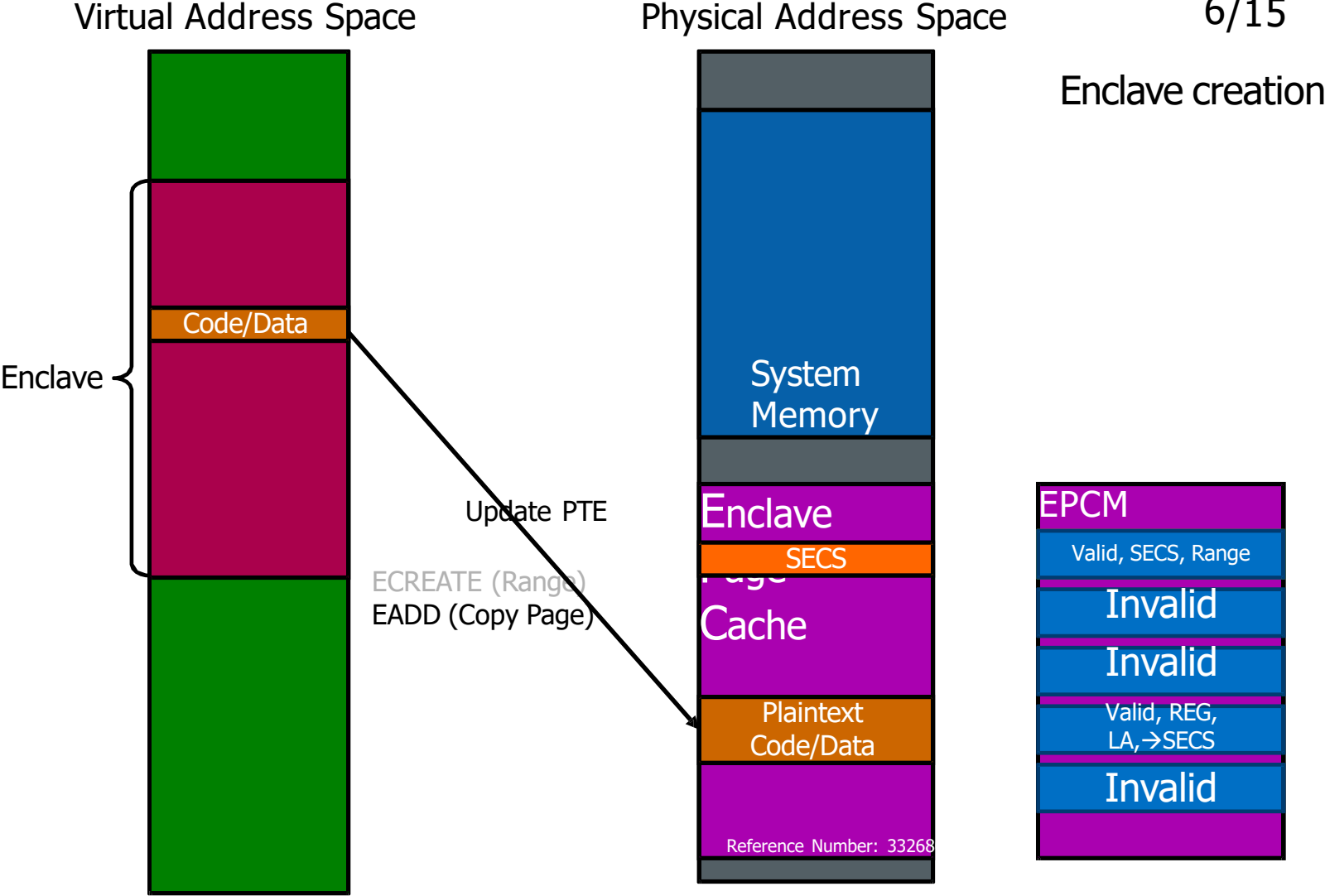
5/15



Life Cycle of An Enclave

Build

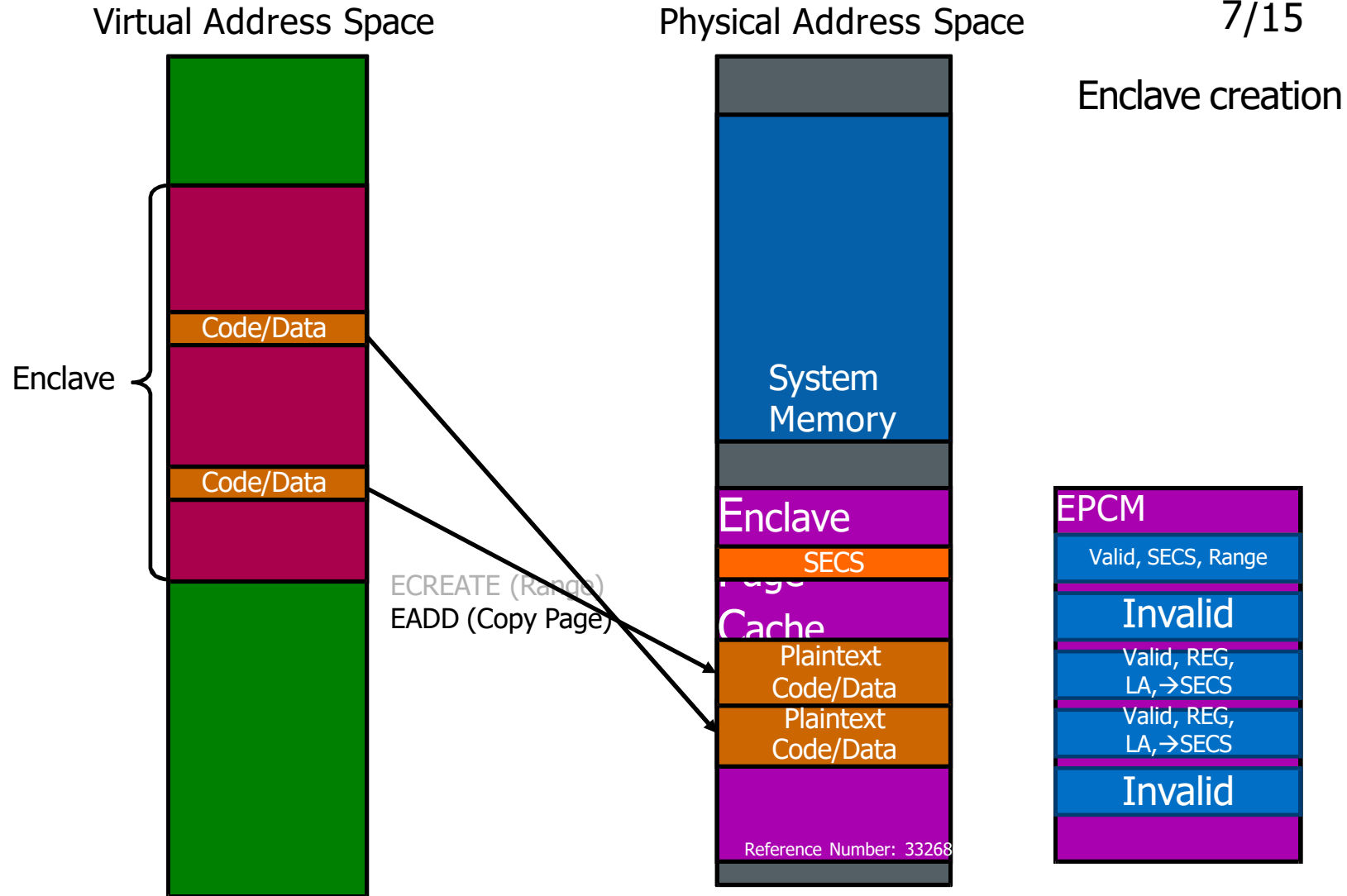
6/15



Life Cycle of An Enclave

Build

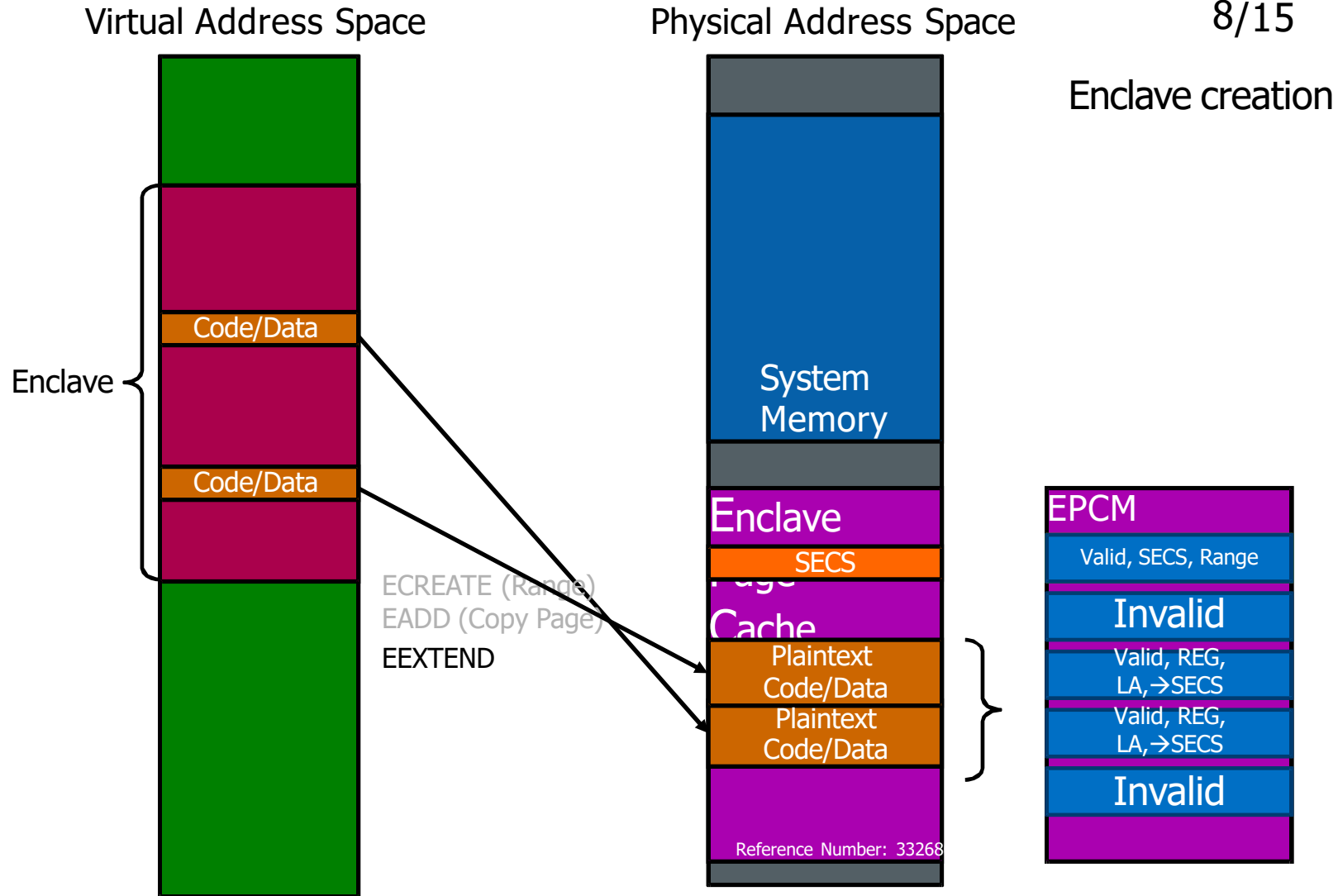
7/15



Life Cycle of An Enclave

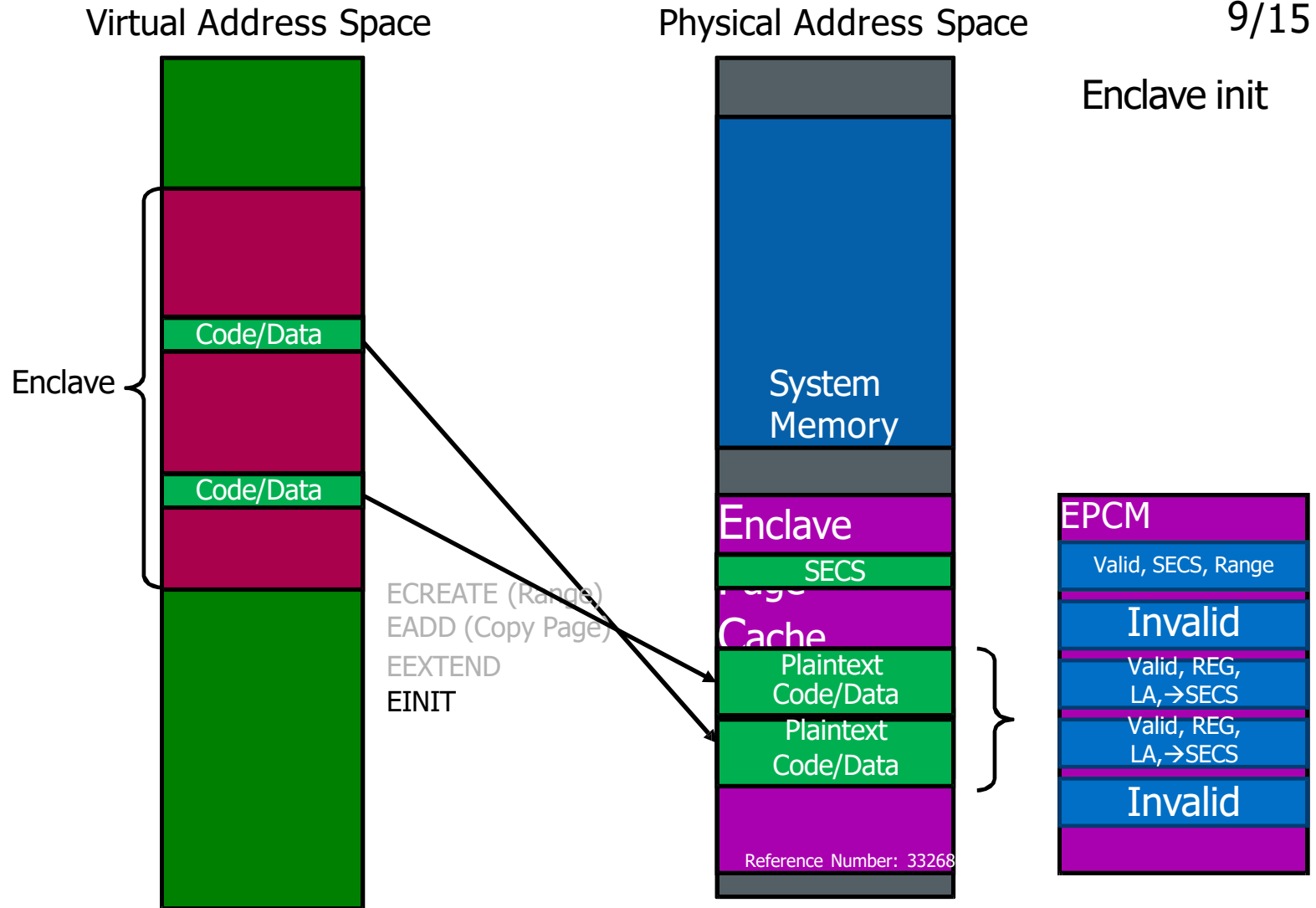
Build

8/15



Life Cycle of An Enclave

Build

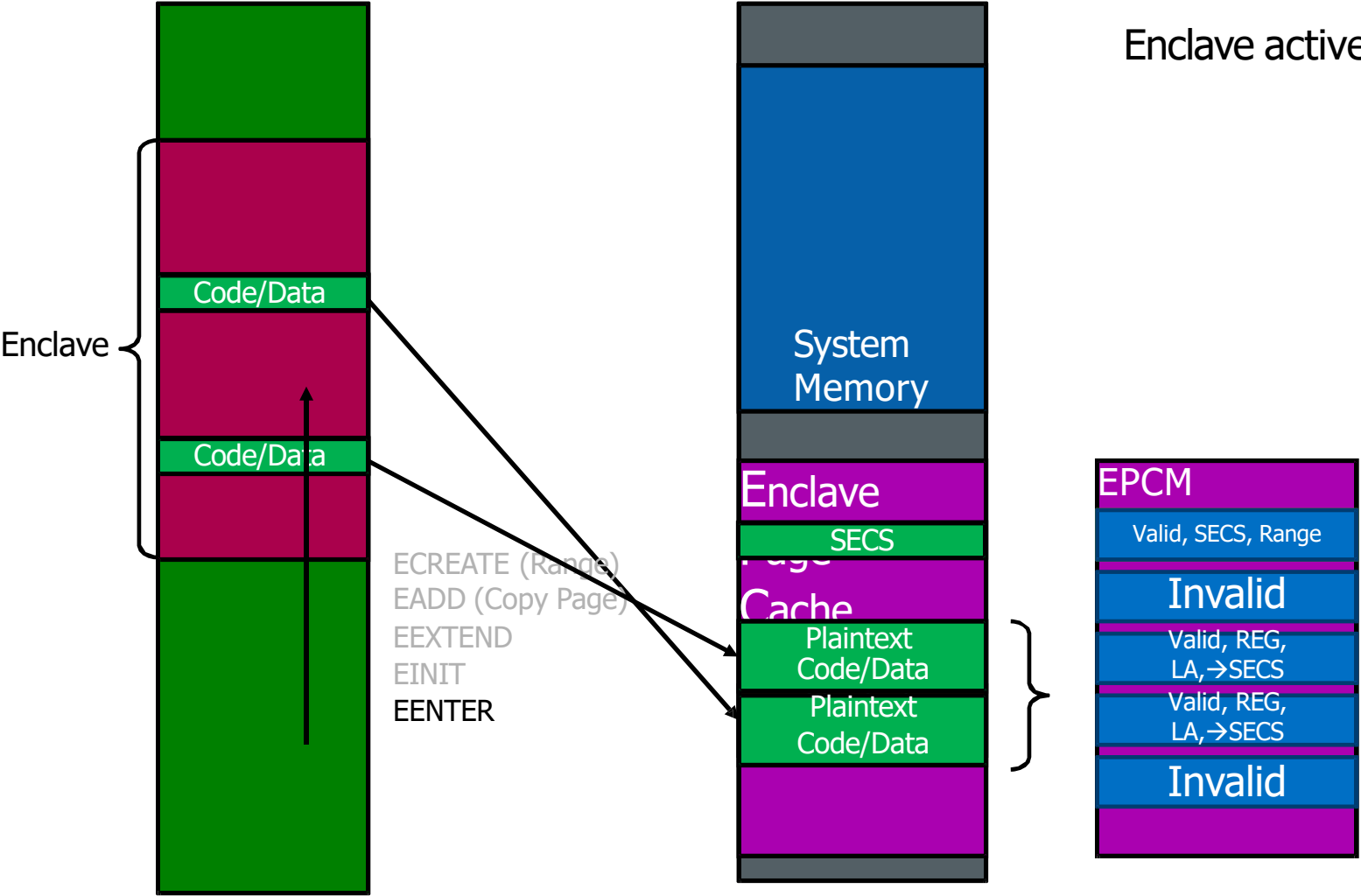


Build

Physical Address Space

10 /15

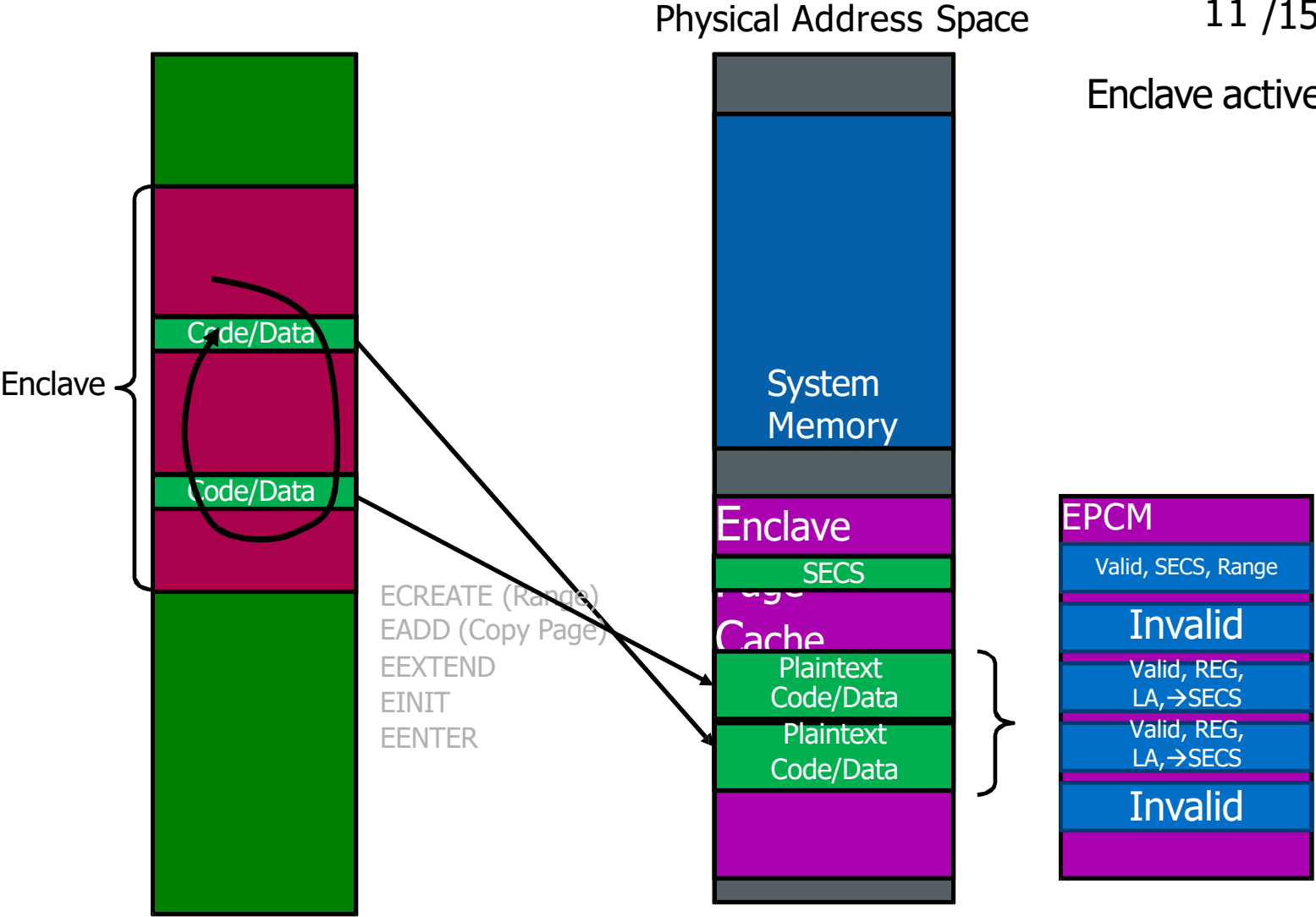
Enclave active



Build

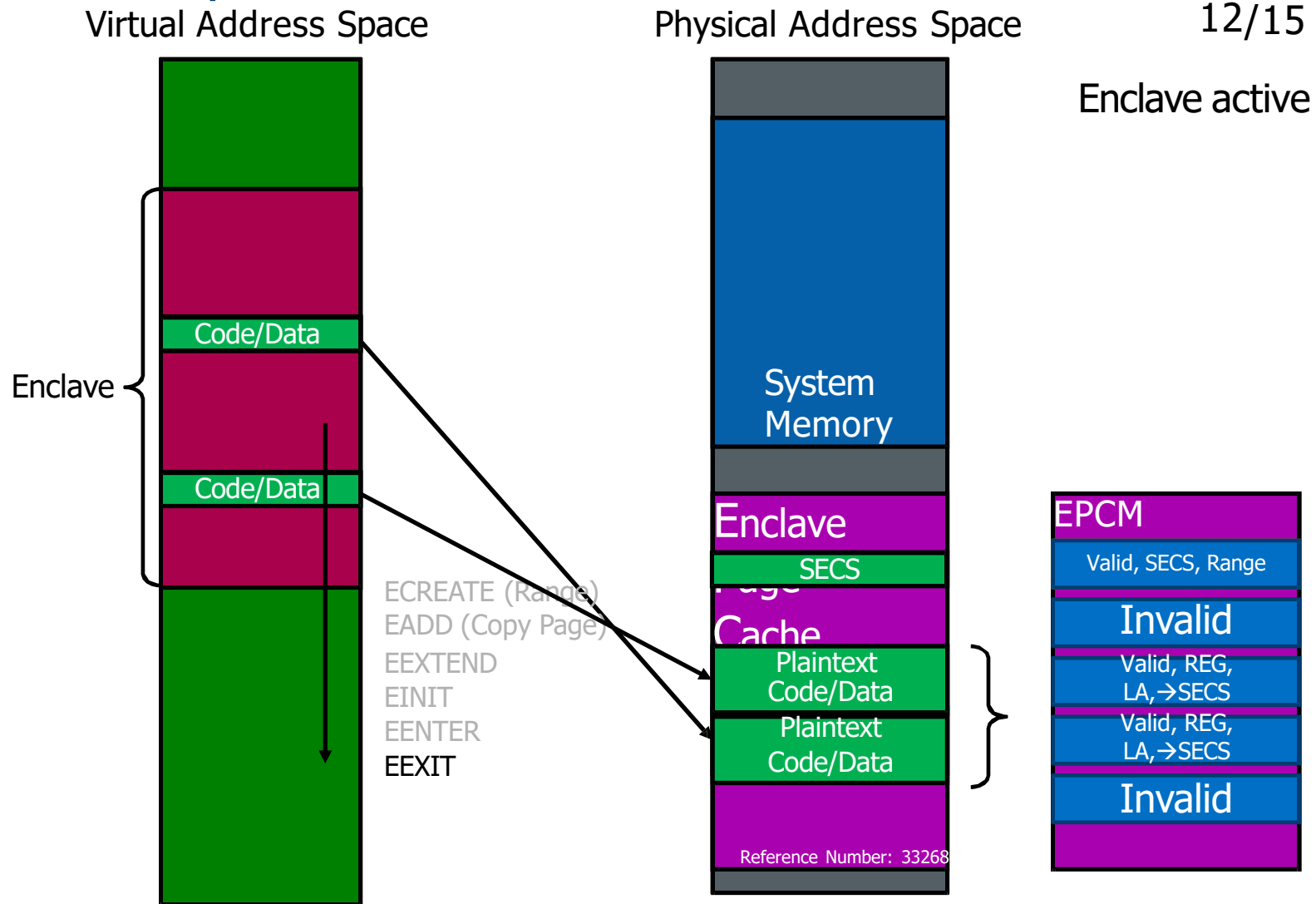
11 /15

Enclave active



Life Cycle of An Enclave

Build

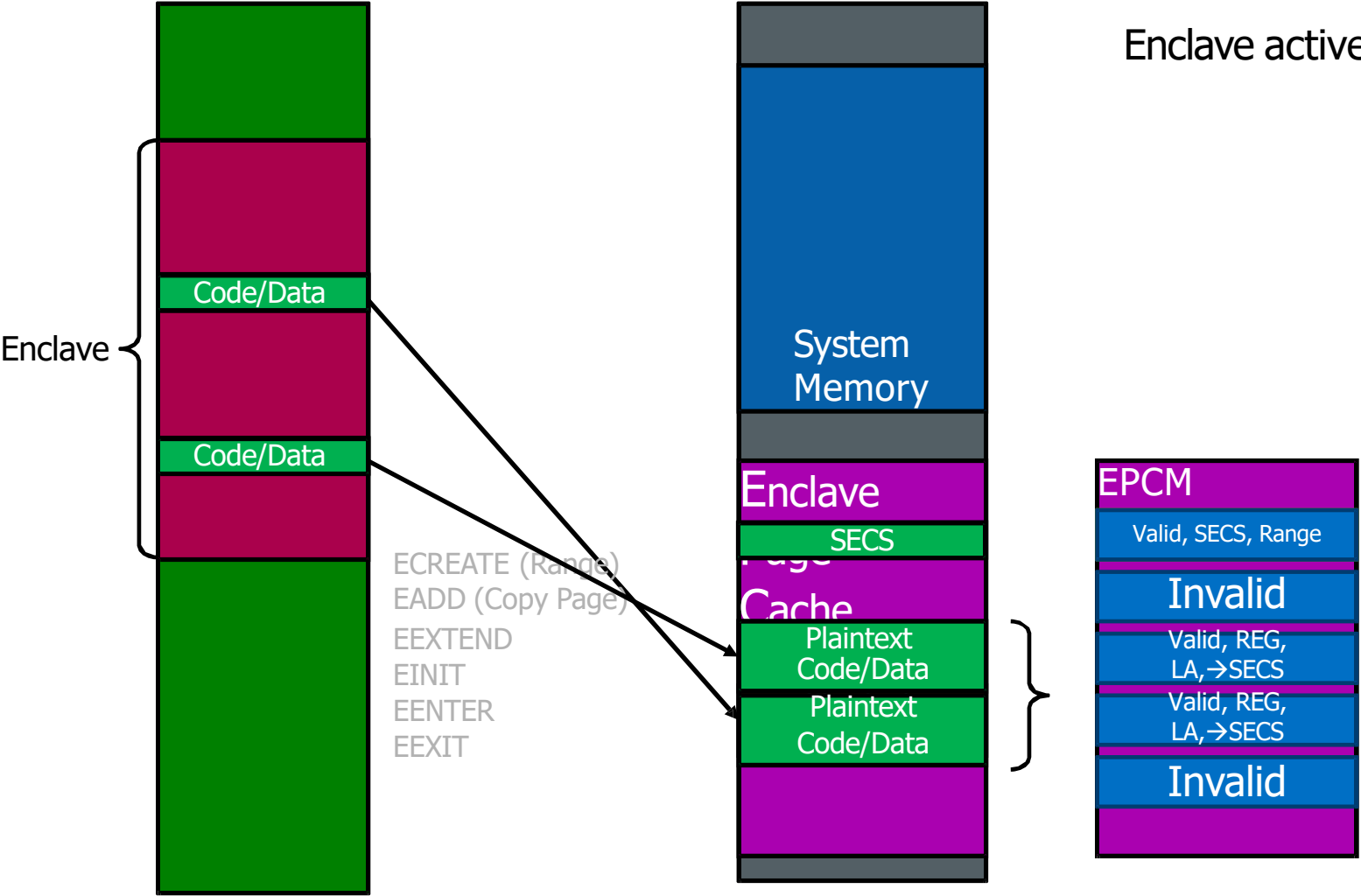


Build

13 /15

Enclave active

Physical Address Space



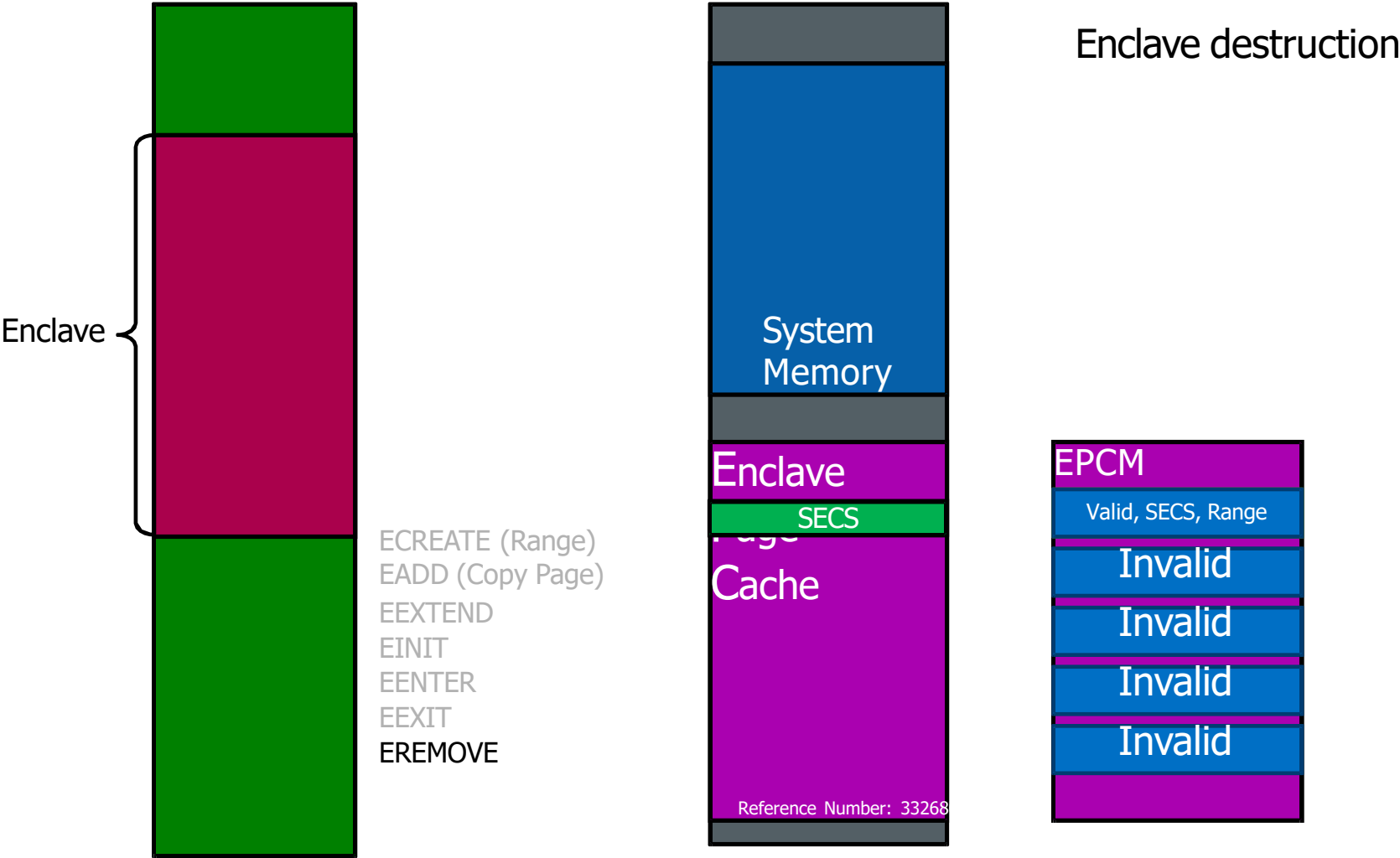
Life Cycle of An Enclave

Build

Virtual Address Space

Physical Address Space

14 /15



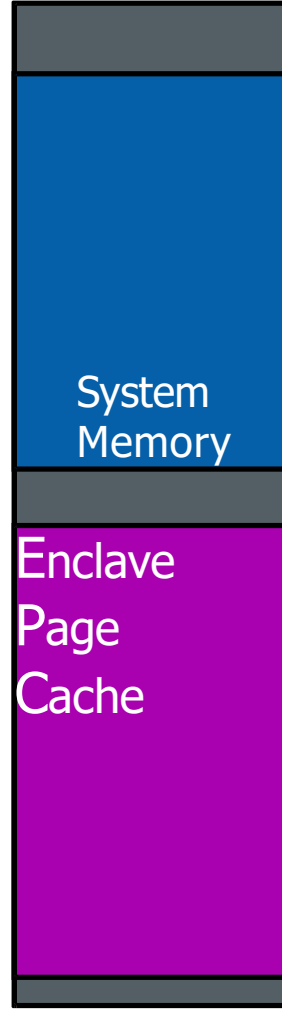
Life Cycle of An Enclave

Virtual Address Space



ECREATE (Range)
EADD (Copy Page)
EEXTEND
EINIT
EENTER
EEXIT
EREMOVE

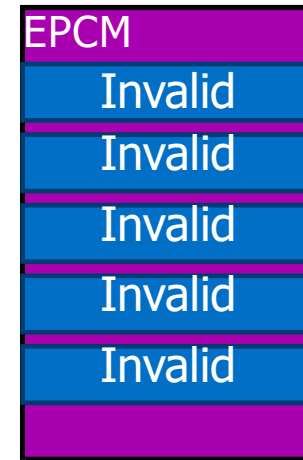
Physical Address Space



Build

15 /15

Enclave destruction



Side channels?



FORESHADOW

Breaking the Virtual Memory Abstraction with Transient Out-of-Order Execution

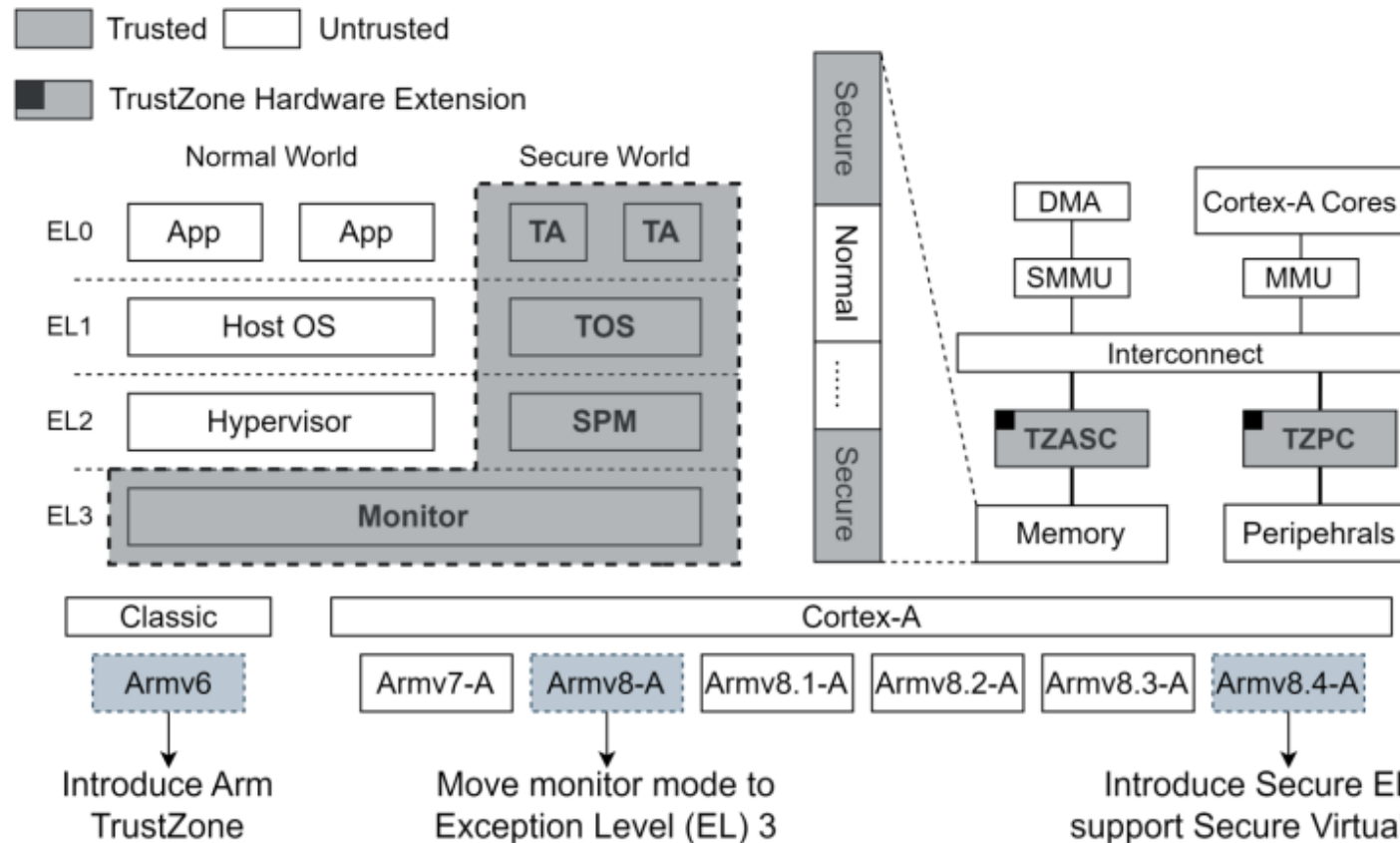


How a little bit of undervolting can cause a lot of problems

Side channels?

- All are possible 😊 CS773, why?
- SGX's goal was not to mitigate side channels but instead to provide security in cloud-based environments.
- AMD has similar ideas in the form of AMD SEV
- Also known as confidential compute architecture (CCA)

What about ARM? Arm TrustZone

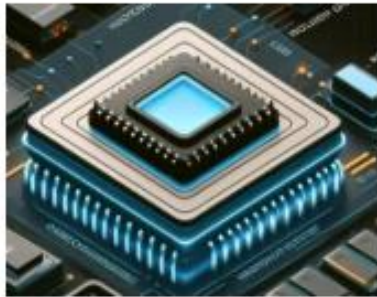


SPM: Secure partition manager
TOS: Trusty OS partitions

It is 2025, what can be done to identify all? Fuzzing

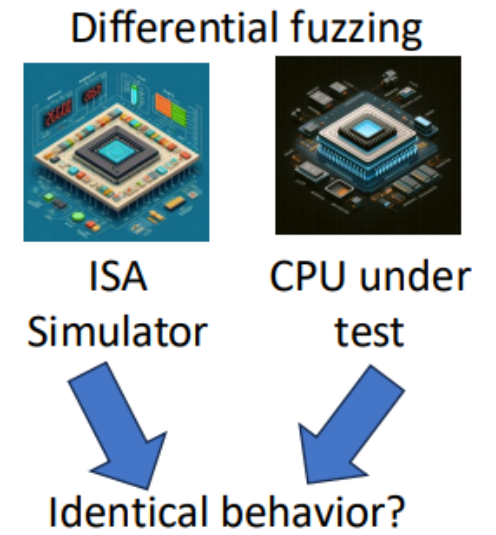
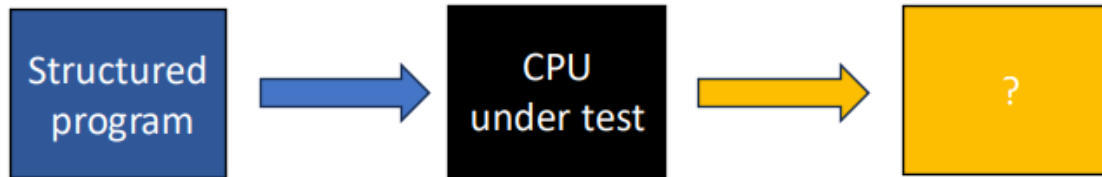
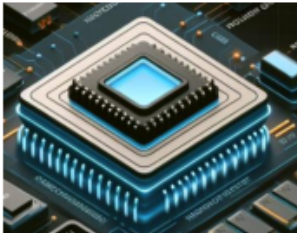
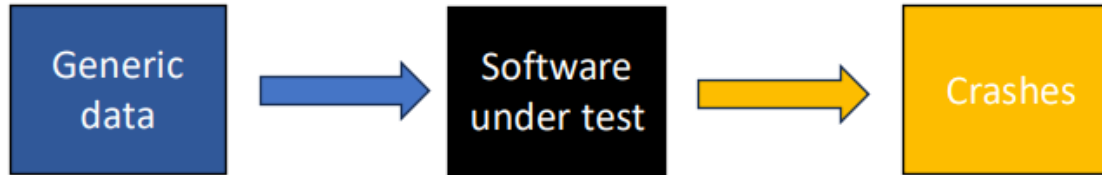


Software
under test



CPU
under test

Tell me more



Differential Fuzzing?

Differential fuzzing with an Instruction Set Architecture (ISA) simulator involves comparing the outputs of different implementations (e.g., a CPU RTL and an ISA simulator) of the same ISA when given identical inputs, to identify potential bugs and vulnerabilities.

ISA simulation vs Real CPU (RTL) simulation

The major difference between RTL and ISA simulation is that the RTL simulation is aware of a cycle concept, representing a clock cycle of the synchronous circuit. Thus the cycle accurate behaviors of the design including microarchitectural states are tested during the simulation, which cannot be performed with the ISA simulation.

Generate a program (in the case of the CPU, instruction sequence) of various control and data flow and see if the CPU behaves differently or inappropriately.

Done on open-sourced CPU only

- RISC-V based CPU
- RTL code is online
- Play with the RTL code